

Manual 50 — Matriz global de governança de IA

Fonte de publicação: edição controlada pt-BR

Linha de base de atualidade: 1 de setembro de 2026

Objetivo

Este manual fornece uma matriz prática entre o EU AI Act, ISO/IEC 42001, NIST AI RMF 1.0 e AI 600-1, os frameworks de governança de IA de Singapura e AI Verify, os Princípios de IA da OCDE e a Fundação Universal de Governança de IA do repositório. Destina-se à implementação, preparação para auditoria, reutilização de evidências, treinamento e governança executiva. Não afirma que regimes diferentes sejam jurídica ou tecnicamente equivalentes.

Regra central: harmonizar controles sem apagar diferenças

Um controle empresarial comum pode apoiar vários regimes, mas cada fonte mantém seu próprio escopo, status normativo, definições de atores, limiares, método de assurance, expectativas documentais e requisitos de evidência. Lei vinculante governa o mapeamento jurídico. Normas e frameworks voluntários continuam voluntários salvo incorporação por lei, contrato ou compromisso interno. Certificação ISO, avaliação de conformidade da UE, testes AI Verify, TEVV alinhado ao NIST e auditoria interna são mecanismos distintos.

Taxonomia de relacionamento

- ****Direto:**** trata materialmente o mesmo objetivo de controle no nível relevante.
- ****Parcial:**** cobre apenas parte do objetivo e exige evidência adicional.
- ****De suporte:**** ajuda a habilitar o objetivo, mas não é suficiente sozinho.
- ****Contextual:**** informa intenção de governança ou princípios sem criar o mesmo requisito.
- ****Nenhum / N/A:**** não existe relação defensável para o escopo avaliado.

Um mapeamento em branco ou qualificado é preferível a uma equivalência sem suporte.

Vinte objetivos comuns de controle

GC-01 Governança e accountability

Estabelecer responsáveis, direitos decisórios, políticas, escalonamento, exceções e supervisão gerencial. Evidências típicas incluem charter de governança, RACI, aprovações de políticas, decisões de comitê e relatórios gerenciais.

GC-02 Inventário e propriedade de IA

Manter inventário atualizado de sistemas e casos de uso de IA com proprietário, finalidade, modelo/provedor, estágio do ciclo de vida, geografia, sensibilidade dos dados, dependências e nível de risco.

GC-03 Responsabilidade por papel e cadeia de valor

Determinar quem projeta, fornece, implanta, importa, distribui, integra, opera ou modifica materialmente a IA. Preservar as definições jurídicas de atores do EU AI Act.

GC-04 Classificação e nível de risco

Aplicar a classificação exigida pela fonte relevante e manter uma classificação interna para definir profundidade de governança. Não confundir classificação jurídica da UE, tier interno, avaliação contextual NIST e avaliação de Singapura.

GC-05 Avaliação de risco e impacto

Identificar finalidade, contexto, partes afetadas, benefícios, danos, uso indevido previsível, dependências, controles, risco residual e decisão responsável antes da implantação e após mudanças materiais.

GC-06 Governança de dados e privacidade

Governar proveniência, qualidade, direitos, acesso, minimização, linhagem, retenção, dados sensíveis, fontes RAG e riscos relacionados a dados. Bases legais e direitos de privacidade permanecem específicos por jurisdição.

GC-07 Segurança, robustez e resiliência

Proteger modelos, aplicações, infraestrutura, agentes, dados, ferramentas e dependências contra ameaças, falhas, abuso e comprometimento da cadeia de suprimentos. Definir recuperação e contenção proporcionais ao risco.

GC-08 Transparência e comunicação

Fornecer informações precisas sobre uso de IA, capacidades, limitações, resultados materiais e responsabilidades ao público apropriado. Deveres legais de transparência permanecem específicos da fonte.

GC-09 Supervisão e intervenção humana

Garantir que pessoas tenham competência, autoridade, informação e meios práticos para intervir em pontos significativos de decisão ou ação. Preservar evidências de aprovação, override, rejeição e escalonamento.

GC-10 Teste, avaliação, verificação e validação

Definir alegações e critérios de aceitação; testar desempenho, segurança, privacidade, robustez e eficácia de controles com evidência reproduzível proporcional ao risco.

GC-11 Documentação e registros

Manter registros técnicos e de governança atualizados sobre desenho, versões, decisões, controles, avaliações, aprovações, incidentes e mudanças materiais.

GC-12 Gates de implantação e aprovação

Exigir uma decisão responsável antes da produção ou expansão material: aprovar, aprovar com condições, restringir, remediar, suspender ou rejeitar.

GC-13 Governança de terceiros e cadeia de suprimentos

Avaliar provedores, modelos, ferramentas, APIs, processadores, hospedagem e dependências de agentes. Cobrir dados, segurança, notificações de mudança, incidentes, continuidade, concentração e saída.

GC-14 Monitoramento e assurance contínuo

Monitorar desempenho, drift, indicadores de risco, negações de política, reclamações, incidentes, mudanças de provedor/modelo, findings abertos e eficácia dos controles.

GC-15 Gestão de incidentes

Detectar, conter, investigar, preservar evidências, remediar e escalar incidentes de IA. Limiares e prazos de notificação externa permanecem específicos por jurisdição.

GC-16 Gestão de mudanças e revalidação

Tratar mudanças em modelo/provedor, dados/RAG, finalidade, população afetada, ferramentas/APIs, autonomia, permissões, geografia ou controles como possíveis gatilhos de revalidação.

GC-17 Auditoria e assurance independente

Aplicar challenge independente proporcional à materialidade e preservar findings, respostas da gestão, evidências de remediação e fechamento.

GC-18 Alfabetização e competência em IA

Garantir competências adequadas para governança, desenvolvimento, implantação, supervisão, segurança, compras, jurídico, auditoria e operações.

GC-19 Melhoria contínua

Usar monitoramento, incidentes, testes, auditoria, feedback, mudanças regulatórias e mudanças do provedor para melhorar controles e governança.

GC-20 Identidade do agente, autonomia, permissões e proveniência das ações

Atribuir identidades rastreáveis, limitar autonomia, aplicar menor privilégio, restringir ferramentas e dados, exigir checkpoints humanos relevantes quando apropriado, preservar proveniência das ações, monitorar e conter.

Guia por família de fontes

EU AI Act

Tratar como lei vinculante dentro de seu escopo. Preservar papéis jurídicos, categorias de sistemas, práticas proibidas, datas de aplicação, transparência, obrigações de alto risco e GPAI, conformidade, registro, monitoramento pós-mercado, incidentes e enforcement quando aplicável. Um controle empresarial genérico é evidência de suporte até que o requisito jurídico exato e o escopo sejam demonstrados.

ISO/IEC 42001

Tratar como norma de sistema de gestão de IA. Mapear em alto nível por objetivos de gestão e controle redigidos de forma independente; não reproduzir texto protegido. Alinhamento não é certificação, e certificação não substitui conformidade legal.

NIST AI RMF 1.0 e AI 600-1

Relacionar controles a GOVERN, MAP, MEASURE e MANAGE e, quando apropriado, às ações específicas de risco de GenAI. NIST continua sendo orientação voluntária e não deve ser apresentado como lei ou certificação.

Singapura e AI Verify

Usar a família Model AI Governance Framework, orientações para GenAI, AI Verify e governança de IA agêntica como referências práticas de governança e assurance. Testes AI Verify não constituem certificação automática nem prova de conformidade em outra jurisdição.

Princípios de IA da OCDE

Usá-los como baseline intergovernamental para crescimento inclusivo e bem-estar, direitos humanos e valores democráticos, transparência e explicabilidade, robustez/segurança e accountability. Não substituem leis jurisdicionais.

Registro de evidências harmonizadas

O conjunto mínimo reutilizável inclui: inventário de IA; charter e RACI; avaliação de risco/impacto; linhagem de dados/RAG; arquitetura de segurança; artefato de transparência; desenho de supervisão humana; pacote TEVV; aprovação de implantação; avaliação de terceiros; monitoramento; registro de incidente; mudança/revalidação; auditoria independente; treinamento; backlog de melhoria; e proveniência de ações de agentes.

Para cada evidência reutilizada registrar: evidência → controle de origem → relação com a fonte alvo → suficiência e limitações → evidência adicional específica → responsável → data/versão.

Cenários práticos

Assistente GenAI empresarial

Exige inventário, avaliação de provedor, linhagem RAG, risco, arquitetura de segurança, testes, transparência, aprovação, monitoramento e incidentes. A análise da UE também determina papel jurídico e obrigações aplicáveis; NIST AI 600-1 aprofunda riscos de GenAI; Singapura apoia governança e testes; ISO/IEC 42001 fornece a camada de sistema de gestão; OCDE informa accountability, transparência e robustez.

IA em contratação

Combinar análise jurídica e de direitos, viés/equidade, supervisão humana, documentação, monitoramento, recurso/escalonamento e gestão de mudanças. Uma avaliação comum pode ser reutilizada, mas classificação da UE e obrigações locais exigem análise separada.

Fluxo agêntico com acesso a ferramentas

Adicionar identidade do agente, menor privilégio, allowlists, limites de ação, checkpoints de aprovação, logs de proveniência, mecanismos de contenção e testes de abuso.

Mudança de modelo do provedor

Detectar a mudança, avaliar materialidade, repetir testes relevantes, atualizar risco/transparência e emitir nova decisão de implantação quando necessário.

Assurance multirregime

Um pacote TEVV pode apoiar várias fontes somente quando tipo de relação, escopo, suficiência, limitações e evidências adicionais forem documentados. Nunca converter isso em percentual universal de conformidade.

Método de análise de gaps

Para cada controle: identificar o controle implementado; determinar fontes aplicáveis; atribuir tipo de relação; identificar requisitos específicos ausentes; classificar o gap como controle, evidência, interpretação jurídica, processo, assurance ou competência; priorizar P1/P2/P3; atribuir responsável e data; retestar e atualizar a justificativa.

Regras contra falsa equivalência

Não publicar percentuais universais de conformidade entre regimes diferentes. Não afirmar que certificação ISO comprova conformidade com o EU AI Act, que adoção do NIST equivale a conformidade legal ou que AI Verify equivale a certificação em outra jurisdição. Preservar incerteza explicitamente e obter interpretação jurídica qualificada quando necessária.

Controle de atualidade

Antes de cada release controlado, revalidar a baseline jurídica do EU AI Act, edição/status da ISO/IEC 42001, status do NIST AI RMF e AI 600-1, versões atuais dos frameworks de Singapura e status dos Princípios de IA da OCDE.

Critério de conclusão

O manual está completo quando cada conclusão da matriz é rastreável a uma família de fonte, tipo de relação, objetivo comum, classe de evidência reutilizável, nota de diferença e delta específico da fonte. O objetivo é reutilização defensável de governança — não equivalência artificial.